

Слайд 1. Титул (≈ 15 с)

Уважаемые члены комиссии! Меня зовут Шестаков Влад, представляю выпускную квалификационную работу на тему «Разработка концепции физического генератора случайных чисел». Научный руководитель — старший преподаватель Дмитрий Александрович Савинов.

Слайд 2. Актуальность (≈ 55 с)

Случайные числа — основа всей современной криптографии: ключи шифрования, инициализация TLS, мессенджеры, банковские транзакции, IoT-устройства, аппаратные кошельки. Миллиарды ключей в год.

При этом массовые микроконтроллеры — Arduino, ESP32, базовые серии AVR и STM32 — не имеют встроенного аппаратного TRNG.

Современные стандарты — NIST SP 800-90B и ГОСТ Р 34.10 — прямо требуют физического источника энтропии для ключевого материала; чисто алгоритмический генератор для криптографических целей неприемлем.

Цена ошибки хорошо известна: в 2012 году дефект генератора в Android привёл к тому, что около 86 процентов биткойн-ключей на уязвимых устройствах оказались предсказуемыми. Атака ROCA сделала уязвимыми миллионы сертифицированных TPM-модулей Infineon.

(Стандарты. NIST SP 800-90B «*Recommendation for the Entropy Sources Used for Random Bit Generation*» — опубликован Национальным институтом стандартов и технологий США в январе 2018 г. (проекты с 2012). Регламентирует требования к физическим источникам энтропии: модель IID/non-IID, обязательная оценка минимальной энтропии (Most Common Value, predictor-based estimators), тесты health на стадии работы. На него опираются FIPS 140-3 (2019) для сертификации криптомодулей. ГОСТ Р 34.10-2012 (Росстандарт, действует с 1 января 2013 г.) — стандарт ЭЦП на эллиптических кривых; для каждой подписи требуется случайное число $k \in [1, q - 1]$, и норма явно требует криптографически качественного генератора. Смежные нормы: ГОСТ Р 8.736-2011 на метрологию ГСЧ, ГОСТ Р 34.11-2012 (хэш «Стрибог»).

Android 2012. В версиях Android до 4,2 класс `SecureRandom` из JCA-провайдера Apache Harmony инициализировался с дефицитной энтропией: seed не дополнялся из `/dev/urandom`. Bitcoin-кошельки используют ECDSA на кривой `secp256k1`, где для каждой транзакции нужно одноразовое случайное k ; если два разных сообщения подписаны одинаковым k , закрытый ключ восстанавливается тривиально. Анализ блокчейна показал: ≈ 86% адресов, сгенерированных уязвимыми Android-кошельками, имели коллизии k — закрытые ключи (и средства) скомпрометированы.

ROCA (CVE-2017-15361). Уязвимость в библиотеке RSALib фирмы Infineon (встроена в TPM, смарт-карты, токены Yubikey 4, эстонские ID-карты — миллионы устройств). Для ускорения простые числа p, q генерировались по формуле $p = k \cdot M + (65537^a \bmod M)$, где M — произведение малых простых. Это даёт публичному модулю $N = pq$ специфический «отпечаток», позволяющий применить улучшенный метод Coppersmith и факторизовать N за часы для 1024-битных и недели для 2048-битных ключей. Открытие группы Matus Nemec et al. (Masaryk University) в 2017 г.)

Слайд 3. Цель и задачи (≈ 30 с)

Цель работы — сравнить физические источники энтропии и на этой основе спроектировать компактный аппаратный TRNG, удовлетворяющий критериям случайности по пакету NIST STS при минимальной стоимости и простоте

реализации.

Задачи: теоретический анализ восьми классов источников, сборка стенда на доступной элементной базе, практическая проверка шести каналов, оценка по NIST STS, скорости генерации и стоимости.

Слайд 4. Классификация ГСП (≈ 25 с)

Все генераторы делятся на два класса. ГПСП — программные псевдослучайные: выход полностью определяется алгоритмом и начальным значением, при знании семени — предсказуем. ГИСП — истинные физические: основаны на недетерминированном процессе. Именно второй класс — предмет работы.

(Принцип ГПСП. Под капотом — конечный детерминированный автомат: состояние x_n , функция перехода $x_{n+1} = f(x_n)$, функция выхода $o_n = g(x_n)$; весь поток задаётся начальным состоянием x_0 — семенем (seed). Линейный конгруэнтный (LCG, простейший): $x_{n+1} = (a \cdot x_n + c) \bmod m$ — так устроены `rand()` в C и `random()` в Arduino. Mersenne Twister — стандартный ГПСП в Python, R, Matlab; период $2^{19937} - 1$, состояние 624 слов, но не криптостойкий: по 624 последовательным выходам полностью восстанавливается всё внутреннее состояние. Криптографические ГПСП (CSPRNG): AES-CTR-DRBG, ChaCha20, HMAC-DRBG — их выход неотличим от случайного за полиномиальное время даже при частичном знании состояния. Любой ГПСП в принципе не может быть TRNG: одинаковый seed $\Rightarrow$ одинаковый поток. Поэтому ему обязательно нужен физический источник для seeding'a — именно его и собирает данная работа.)

Слайд 5. Физические источники энтропии (≈ 35 с)

В теоретической части рассмотрены восемь классов источников. Электронные: тепловой шум Джонсона-Найквиста, дробовой шум, лавинный шум обратного пробоя полупроводникового перехода, мерцающий шум вида один на эф. Прочие: оптические и квантовые источники, радиоактивный распад, акустические шумы и MEMS-инерциальные датчики.

Для каждого рассмотрены физическая модель, спектральная характеристика и применимость в массовой реализации.

(Тепловой шум (Джонсон 1928, Найквист 1928) — флуктуации напряжения на резисторе из-за хаотичного движения носителей; СПМ $S_v = 4kTR B^2/\text{Гц}$, белый. Физический предел любого резистивного устройства; используется как референс шума.

Дробовой шум (Шоттки 1918) — следствие дискретности заряда при прохождении тока через потенциальный барьер; СПМ тока $S_i = 2qI A^2/\text{Гц}$, белый. Наблюдается в диодах, фотодиодах, вакуумных лампах.

Лавинный шум — при обратном смещении p-n перехода выше напряжения пробоя U_{BR} возникает ударная ионизация, лавинообразное размножение носителей; СПМ типа дробового, домноженная на множитель умножения M^2 и избыточный шум-фактор F : $S_i = 2qIM^2F$. Большая амплитуда, удобно для практических TRNG, — в данной работе именно этот источник принят как основной.

Мерцающий $1/f$ (фликкер-шум) — следствие захвата носителей на ловушки в полупроводниковом материале; СПМ $\propto 1/f$, доминирует на низких частотах. Нежелателен: даёт долговременные корреляции, снижающие энтропию.

Оптические / квантовые — например, расщепление одиночного фотона на полупрозрачном зеркале или поляризационное измерение. Чистый квантовый источник, фундаментально недетерминированный. Применяется в коммерческих QRNG (ID Quantique).

Радиоактивный распад — моменты распадов ядер квантово случайны; фиксируются

счётчиком Гейгера. Эталонный TRNG, требует радиоактивный материал (исторически — сервис HotBits, Walker 1996).

Акустический — микрофон фиксирует звук среды (тепловой шум воздуха, вибрации). Зависит от обстановки: в тишине источник «гаснет».

MEMS-инерциальный — шумы микроакселерометров/гироскопов в смартфонах; сочетают тепловой шум подвижной массы и шум АЦП внутри датчика. Слабый, но бесплатный на устройствах с уже встроенным MEMS.)

Слайд 6. Архитектура стенда (≈ 40 с)

Стенд построен по модульной архитектуре: разные физические источники изолированы, но проходят через единый конвейер. Аппаратная база — Arduino Nano с микроконтроллером ATmega328P. Источник шума усиливается аналоговым трактом на операционном усилителе, оцифровывается АЦП, по последовательному каналу на скорости один мегабайт передаётся на ПК. На стороне ПК — извлечение младших разрядов, постобработка, статистический анализ, прогон NIST STS.

(Каждый источник имеет свою прошивку, но единый бинарный протокол — uint16 little-endian с ASCII-баннером метаданных. Скорость один мегабайт — «родная» для UART ATmega328P на 16 МГц, ноль процентов ошибки делителя. Эффективная частота отсчётов ≈ 49,6 кГц, упирается именно в линию связи. На ПК конвейер реализован на Python.)

Слайд 7. Аналоговый усилительный тракт (≈ 40 с)

Аналоговый тракт реализован как двухкаскадный неинвертирующий усилитель на сдвоенном ОУ LM358 при однополярном питании двенадцать вольт. Опорное напряжение смещения формируется отдельным делителем от шины пять вольт Arduino. Каскады соединены через резистор, без разделительного конденсатора — чтобы сохранить низкочастотные составляющие сигнала. Суммарный коэффициент усиления — порядка пятисот.

(Каждый каскад — типовое включение $1 + R_f/R_g$. Первый каскад: $R_g = 10\text{ к}$, $R_f = 470\text{ к}$, $G_1 \approx 48$. Второй: $R_g = 10\text{ к}$, $R_f = 100\text{ к}$, $G_2 \approx 11$. Итог: $G \approx 528$. LM358 выбран потому, что его выход доходит до нижней шины — это позволяет использовать весь диапазон АЦП 0...5 В даже при питании ОУ от +12 В. TL072 — тише по шуму, но не rail-to-rail, и в однополярном режиме срезает нижние 1,5...2 В диапазона; поэтому использовался только в тепловом канале, где собственный шум ОУ важнее динамики.)

Слайд 8. Лавинный пробой ВЕ-перехода (≈ 40 с)

Основным предметом исследования стал канал лавинного шума обратносмещённого ВЕ-перехода биполярного транзистора BC337. Транзистор включён инвертированно: коллектор и база на землю, эмиттер через балластный резистор сто килоом подтянут к двенадцати вольтам. При таком напряжении ВЕ-переход выходит в режим лавинного пробоя, и случайный характер ударной ионизации даёт интенсивный широкополосный шум. Полезный сигнал снимается с эмиттера через разделительный конденсатор и подаётся на вход усилителя.

(Изначально пробовался 2N3904, но он не вышел в лавинный режим даже при +12 В — паспортный диапазон U_{BR} относится к худшему случаю, фактические экземпляры могут пробиваться выше типового. BC337 устойчиво заработал. Балластный 100 кОм ограничивает ток лавины ~10...50 мкА. Конденсатор 0,1 мкФ отсекает постоянную составляющую ≈ U_{BR} на эмиттере, иначе вход усилителя был бы перегружен DC.)

Слайд 9. Развитие ГИСП на основе ВЈТ (≈ 60 с)

Канал ВЈТ прошёл четыре итерации.

Этап 1 — одиночный каскад с усилением около пятидесяти: сигнал занимает лишь пятую часть шкалы АЦП.

Этап 2 — добавление второго каскада, усиление выросло до пятисот двадцати восьми, размах достиг полной шкалы, но появилась систематическая аномалия — насыщение на верхней границе АЦП.

Этап 3 — две согласованные правки: смещение опорного напряжения вниз и снижение усиления (добавочный 680 килоом параллельно резистору обратной связи второго каскада, общий коэффициент упал примерно до четырёхста шестидесяти семи). Насыщение исчезло; именно снижение усиления, а не само устранение насыщения, объясняет уменьшение сигмы со 145 до 122.

Этап 4 — добавочный резистор снят, усиление возвращено к пятисот двадцати восьми, плюс введена развязка по питанию двумя конденсаторами и применён более стабильный лабораторный блок питания. Эта конфигурация принята как итоговая.

(V_{mid} смещён до $\approx 1,67$ В путём добавления второго 10 к параллельно нижнему плечу делителя — без перепайки уже собранной платы. Качество разных блоков питания оценивалось тем же измерительным трактом: вместо источника шума на вход подавалась шина +12 В через 0,1 мкФ — конденсатор отсекает постоянку, а пульсации усиливаются $\times 500$ и видны в реальном времени в «осциллографе» `serial_scope`. Это позволило выбрать самый «тихий» БП без отдельного осциллографа.)

Слайд 10. Постобработка битового потока (≈ 50 с)

Базовый алгоритм — схема фон Неймана. Это прозрачный, некриптографический экстрактор без параметров и начального состояния. Выбор именно его обоснован целью работы: оценить качество физического источника, а не замаскировать его дефекты криптографическим хэшем — SHA-256 прошёл бы NIST STS почти при любом входе.

Помимо фон Неймана исследованы четыре других алгоритма: XOR с задержкой N , XOR нескольких младших разрядов одного отсчёта, XOR-децимация с окном N , и побайтовая XOR-свёртка. Все они применялись либо как самостоятельные методы, либо как второй проход поверх фон Неймана.

(Фон Нейман (1951): входные биты $b_0, b_1, b_2, \dots$ разбиваются на пары, для каждой пары

$$(b_{2i}, b_{2i+1}) \rightarrow \begin{cases} \text{вых. 0,} & (0, 1) \\ \text{вых. 1,} & (1, 0) \\ \text{отброс,} & (0, 0) \text{ или } (1, 1). \end{cases}$$

При независимости пар $\Pr(01) = \Pr(10) = p(1-p)$, поэтому выход строго несмещён независимо от смещения p . Цена — пропускная способность: $\eta = 2p(1-p) \leq 1/2$, в идеальном случае 25%.

XOR с задержкой N : $b'_i = b_i \oplus b_{i-N}$. Сглаживает корреляции с лагом N ; сохраняет размер потока (теряется только первые N бит).

XOR нескольких младших разрядов отсчёта: $b'_i = \text{lsb}_0(x_i) \oplus \text{lsb}_1(x_i) \oplus \dots \oplus \text{lsb}_K(x_i)$. На каждый отсчёт АЦП x_i ровно один выходной бит, объединяет несколько независимых младших разрядов одного отсчёта.

XOR-децимация с окном N : $b'_i = b_{Ni} \oplus b_{Ni+1} \oplus \dots \oplus b_{Ni+N-1}$. Каждые N входных бит сворачиваются в один выходной (поток сжимается в N раз). Это сглаживает корреляции

на лагах до N включительно.

Побайтовая XOR-свёртка: над каждым байтом x независимо: $x \leftarrow x \oplus (x \gg 4)$; $x \leftarrow x \oplus (x \gg 2)$; $x \leftarrow x \oplus (x \gg 1)$. После трёх сдвигов младший бит выхода равен XOR всех восьми бит исходного байта (битовый паритет). Размер потока не меняется; алгоритм линеен по входу — разрушает внутрибайтовые корреляции, но не сжимает.

Каскад «фон Нейман $\rightarrow$ XOR-децимация» применён как итоговая постобработка: первая ступень снимает асимметрию пар, вторая — остаточные корреляции от конечной полосы усилителя.)

Слайд 11. Главный результат (≈ 60 с)

Главный результат работы: на итоговом канале BJT с каскадной постобработкой — фон Нейман плюс XOR-децимация с окном восемь — получено пятнадцать PASS из пятнадцати групп тестов NIST STS, при нулевом числе провалов и нулевом числе неприменимых тестов.

То есть построенный из дешёвых компонентов и без криптографических библиотек источник по статистике полностью совпадает с эталонной случайной последовательностью.

Минимальная энтропия выходного потока — девять девяток после запятой бита на бит, скорость генерации — около полутора килобит в секунду, стоимость элементной базы — менее пятидесяти рублей.

(**Минимальная энтропия** (*min-entropy*) случайной величины X со значениями в $\mathcal{X}$:

$$H_{\infty}(X) = -\log_2 \max_{x \in \mathcal{X}} \Pr(X = x).$$

Для двоичного источника с $\Pr(b=1) = p$: $H_{\infty} = -\log_2 \max(p, 1-p)$. Идеальная случайность: $p = 1/2 \Rightarrow H_{\infty} = 1$ бит/бит. Полученные 0,9999 означают $p_{\max} = 2^{-0,9999} \approx 0,5003$, то есть отклонение от равновероятности в третьем-четвёртом знаке. В отличие от энтропии Шеннона (среднее $-\sum p_i \log_2 p_i$), H_{∞} — консервативная нижняя оценка: учитывает наиболее предсказуемое значение, что и нужно для криптографических гарантий. Именно H_{∞} нормирует NIST SP 800-90B; оценивается из данных методом Most Common Value: $\hat{p}_{\max}$ = доля самого частого значения $\Rightarrow \hat{H}_{\infty} = -\log_2 \hat{p}_{\max}$.

Остальное про слайд. 15 PASS из 15 — включая *RandomExcursions* и *RandomExcursionsVariant*, которые на одиночном фон Неймане проваливаются как раз из-за остаточных структурных корреляций. Скорость 1,6 кбит/с — после двух последовательных сжатий: фон Нейман сжимает $\approx$ в 4 раза, XOR-децимация — ещё в 8 раз, итого $\approx \times 32$ от исходных ~ 50 тыс. бит/с. На картинке справа — фрагмент 512×512 итогового битового потока, визуально неотличим от белого шума.)

Слайд 12. Сравнение источников (≈ 45 с)

Сводная сравнительная таблица всех шести проверенных каналов. Канал BJT с каскадной постобработкой — выделен — даёт одновременно полное прохождение NIST STS, минимальную энтропию выше девяти девяток и низкую стоимость. Тепловой канал — устойчивый средний результат, 10 из 15 PASS, но амплитуда сигнала на порядок ниже. Микрофон, MPU-6050, плавающий АЦП и канал дрожания тактов в наблюдаемой реализации непригодны как самостоятельные источники.

(Плавающий АЦП и *clock jitter* формально имеют *min-H* около 0,9999 — то есть на бит после фон Неймана энтропия близка к идеальной, — но NIST провален весь, потому что бит-энтропия не учитывает структурных корреляций. Это методическое предупреждение: высокая *min-H* не гарантирует прохождения NIST. Микрофон и MPU — слабы по другой

причине: узкая полоса и низкое использование диапазона АЦП.)

Слайд 13. Выводы (≈ 30 с)

По результатам работы: сконструирован стенд, проверены шесть независимых источников энтропии. Лучший результат — канал лавинного шума BJT с каскадной постобработкой: пятнадцать PASS из пятнадцати NIST STS. Показано, что двухступенчатая некриптографическая постобработка эквивалентна криптографическому отбеливанию по эффекту на NIST. Стоимость элементной базы итогового источника — менее пятидесяти рублей.

(Криптографическое отбеливание (cryptographic whitening) — обработка слабоэнтропийного потока криптографическим примитивом так, чтобы выход стал статистически неотличим от равномерно случайного за полиномиальное время. Типовые конструкции: хэш-функция (SHA-256, SHA-3, BLAKE2) над блоками входа; AES в режиме CTR или CBC с ключом, выведенным из энтропии; HMAC-DRBG (NIST SP 800-90A). Свойство: благодаря лавинному эффекту достаточно одного «честного» бита энтропии на блок, чтобы выход прошёл все стандартные статистические тесты. Опасность: маскирует низкое качество источника — даже постоянный вход вида $0,0,0,\dots$ через SHA-256 даст поток, неотличимый от случайного по NIST STS. Поэтому в данной работе криптографическое отбеливание сознательно не использовалось как метод оценки; вместо него — два последовательных прозрачных (линейных, без секрета) преобразования, дающих сопоставимый практический результат.)

Слайд 14. Перспективы (≈ 15 с)

Перспективы: второй независимый канал на отдельной микросхеме ОУ с XOR-смешением битовых потоков; печатная плата с экранированием и малошумящим стабилизатором; упаковка в законченный модуль с собственным микроконтроллером.

Спасибо за внимание, готов ответить на вопросы.

(XOR-смешение независимых источников. Пусть X и Y — независимые битовые потоки с минимальной энтропией $H_\infty(X) = h_x$ и $H_\infty(Y) = h_y$ соответственно. Тогда для $Z = X \oplus Y$ верно $H_\infty(Z) \geq \max(h_x, h_y)$, причём при $h_x, h_y \rightarrow 1$ значение $H_\infty(Z) \rightarrow 1$ экспоненциально быстро (так называемая piling-up lemma): отклонение $|p_Z(1) - 1/2| = 2 \cdot |p_X(1) - 1/2| \cdot |p_Y(1) - 1/2|$, то есть смещения умножаются и стремятся к нулю. Зачем несколько источников: (1) монотонный рост энтропии — XOR никогда не ухудшает выход; (2) скорость не теряется — два потока по r бит/с дают r бит/с на выходе (в отличие от фон Неймана, который сжимает); (3) устойчивость к атакам и наводкам — если один канал полностью скомпрометирован (детерминирован, перехвачен, заглушён), XOR с честным независимым каналом сохраняет качество выхода. Принципиально: все промышленные TRNG (Intel RDRAND, ARM TrustZone) используют именно многоканальную схему с XOR-смешением.)